Informe de Vulnerabilidades Máquina Vulnerable 1

1. **Información General**
   - **Hostname:** Vulnerable1
   - **Dirección IP:** 172.17.0.2
   - **Fecha de inicio:** 05/04/2026

****

2. **Alcance y Objetivo**

El presente informe detalla la evaluación técnica de seguridad realizada sobre el activo **Vulnerable 1**. El objetivo primordial es ejecutar un ciclo completo de penetración que permita identificar debilidades en los servicios expuestos, explotar una vulnerabilidad crítica para obtener acceso inicial y, posteriormente, realizar una escalada de privilegios local hasta comprometer la cuenta de superusuario (root), extrayendo la prueba de compromiso (Flag).

- **Metodología Utilizada**

Para garantizar una evaluación exhaustiva y replicable, se aplicó una metodología de **Pentesting de Caja Negra (Black Box)** basada en el estándar **PTES (Penetration Testing Execution Standard)**

3. **Reconocimiento Inicial**

Se realizó un escaneo completo de puertos y servicios utilizando la herramienta **Nmap**. Se aplicaron scripts de enumeración por defecto y detección de versiones para identificar la superficie de exposición.

- **Comando ejecutado:** nmap -sC -sV -Pn -p- -T4 172.17.0.2

- **Resultados obtenidos luego de ejecutar el comando con Nmap**

```
kali@kali: ~/maquinas_ctf/vulnerable1
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~/maquinas_ctf/vulnerable1]
└─$ nmap -sV  -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-07 03:19 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65521 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.3
22/tcp   open  ssh         OpenSSH 7.9p1 Debian 10+deb10u4 (protocol 2.0)
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.11.5-P4-5.1+deb10u11 (Debian Linux)
80/tcp   open  http        Apache httpd 2.4.59 ((Debian))
110/tcp  open  pop3        Dovecot pop3d
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp  open  imap        Dovecot imapd
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
993/tcp  open  ssl/imap    Dovecot imapd
995/tcp  open  ssl/pop3    Dovecot pop3d
3306/tcp open  mysql       MariaDB 5.5.5-10.3.39
3632/tcp open  distccd?
5432/tcp open  postgresql  PostgreSQL DB 11.19 - 11.22
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: Hosts:  localhost.mshome.net, VULNERABLE1; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.17 seconds

┌──(kali㉿kali)-[~/maquinas_ctf/vulnerable1]
└─$
```

4. Enumeración y Pruebas iniciales

4.1. Enumeración del Servicio FTP (Puerto 21)

En esta fase, el objetivo es verificar si la configuración del servidor permite el acceso sin credenciales y si existen archivos sensibles expuestos en el directorio raíz del servicio.

```
┌──(kali㉿kali)-[~/maquinas_ctf/vulnerable1]
└─$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
```

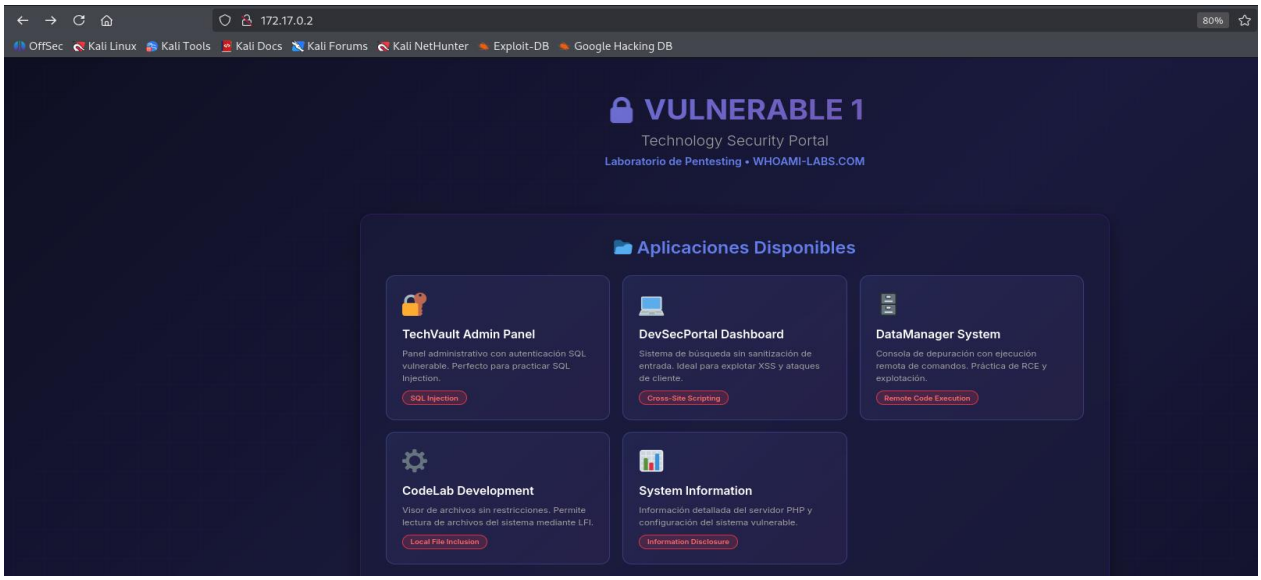
Se confirmó que el servidor vsFTD 3.0.3 permite el ingreso con el usuario: **Anonymous**.

```
ftp> ls -R
229 Entering Extended Passive Mode (|||44168|)
150 Here comes the directory listing.
226 Directory send OK.
ftp>
```

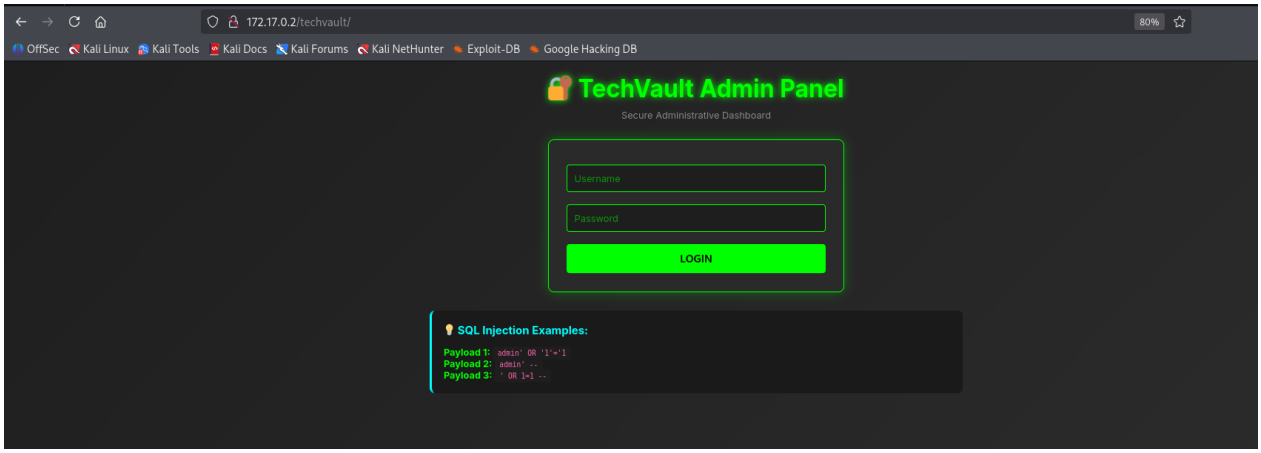
No se identificaron archivos legibles dentro del entorno restringido del usuario anónimo.

4.2. Enumeración de Servicios Web (Puerto 80 - HTTP)

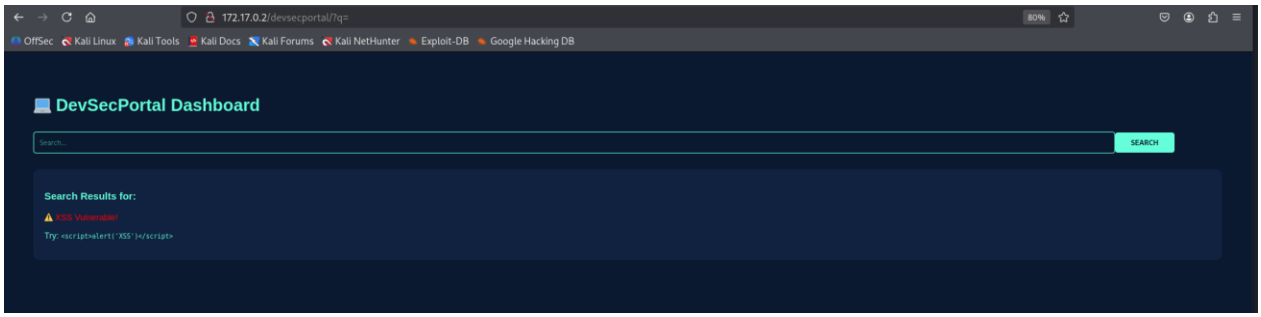
Al acceder al servicio web mediante el navegador, se identificó un portal interactivo titulado **"Aplicaciones Disponibles"**. Este panel expone múltiples vectores de ataque, cada uno asociado a una funcionalidad específica del servidor.



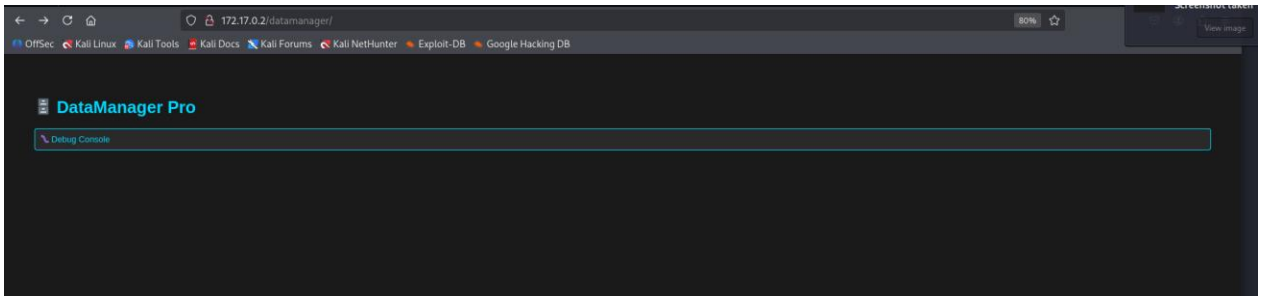
Al hacer click en el link de TechVault Admin Panel, despliega información sobre ejemplos de SQL Injection.

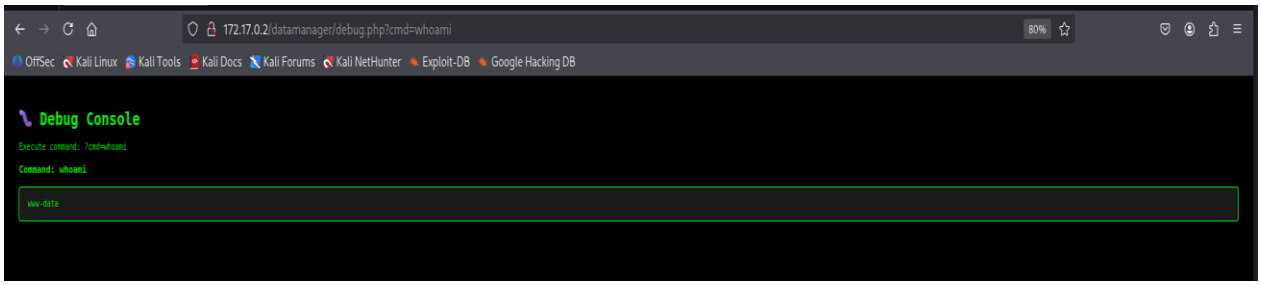


Al hacer click en el icono de DevSecPortal Dashboard, despliega una interface para practicar vulnerabilidades web **XSS (Cross-Site Scripting)**.

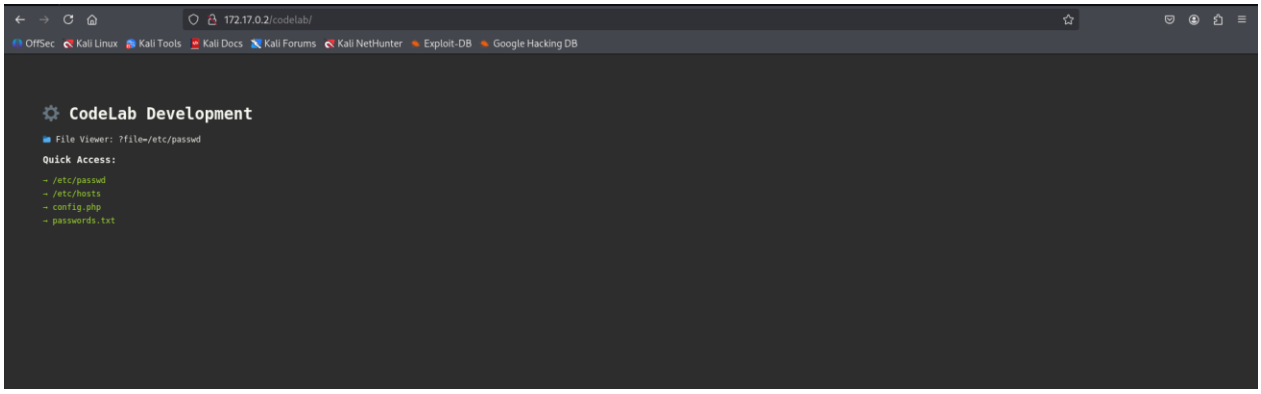


Al hacer clic en el icono DataManager Pro, se encontró una consola donde el programador dejó habilitado el parámetro ?cmd=

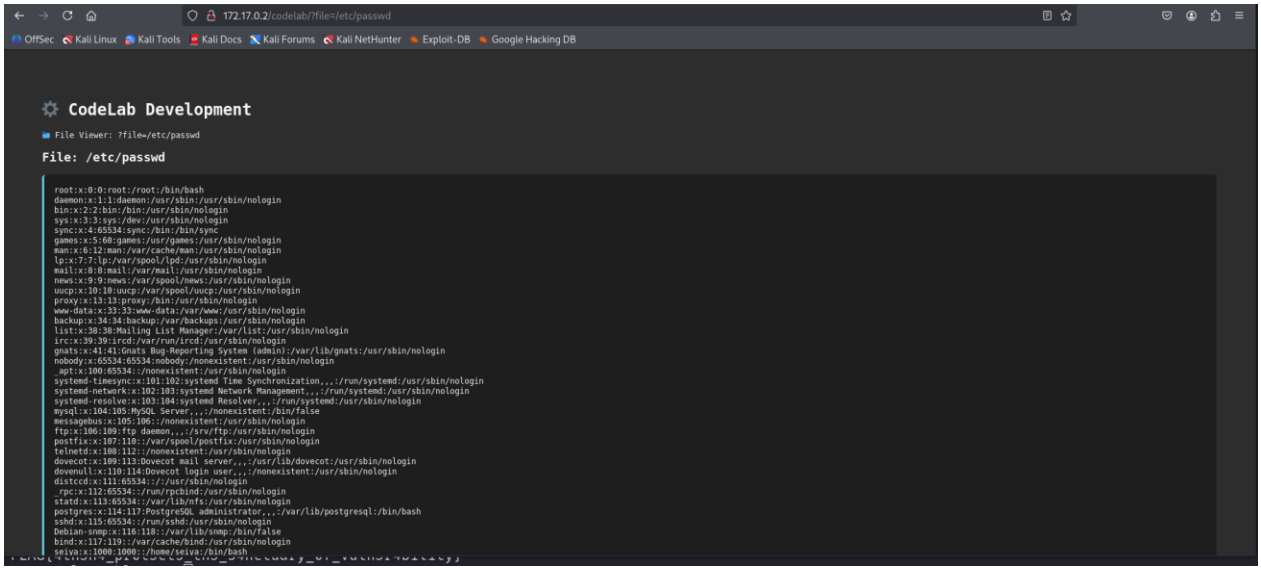




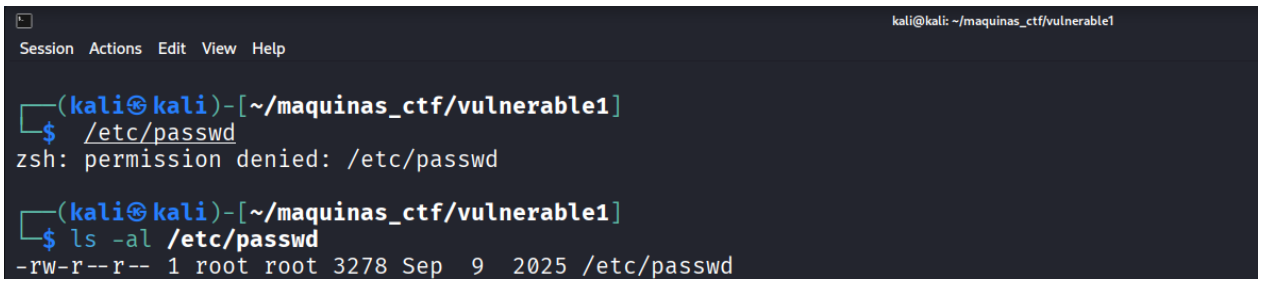
Al hacer clic en el icono CodeLab Development, se visualiza dos carpetas y dos archivos con posible información de la configuración del portal, que presentan una vulnerabilidad crítica conocida como LFI (Local File Inclusión) o Archivos Locales.



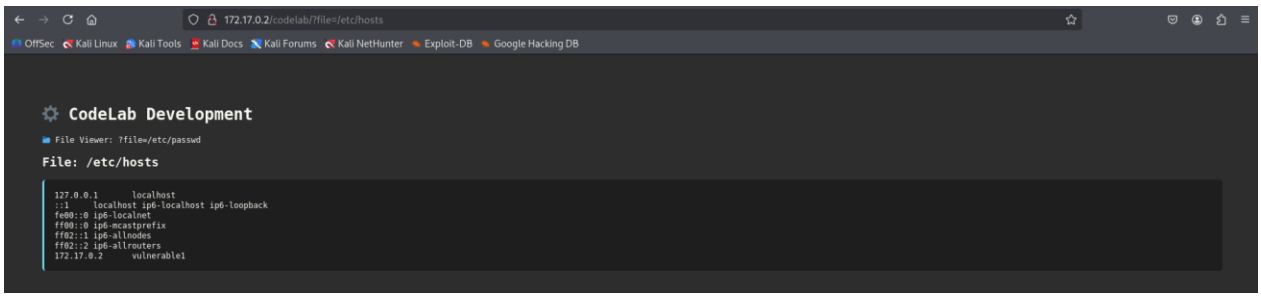
- **etc/passwd**



Se realiza la validación para determinar si te tiene acceso al /etc/passwd y también se determina que no tiene permisos para escritura y ejecución



- **etc/hosts**

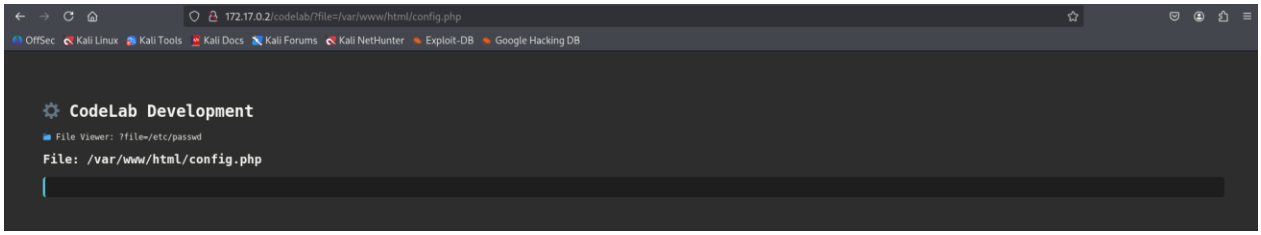


Muestra las direcciones IPs con nombres de equipos(hostname) de forma local.

Se realiza la validación para determinar si te tiene acceso **al /etc/hosts** y también se determina que no tiene permisos para escritura y ejecución.

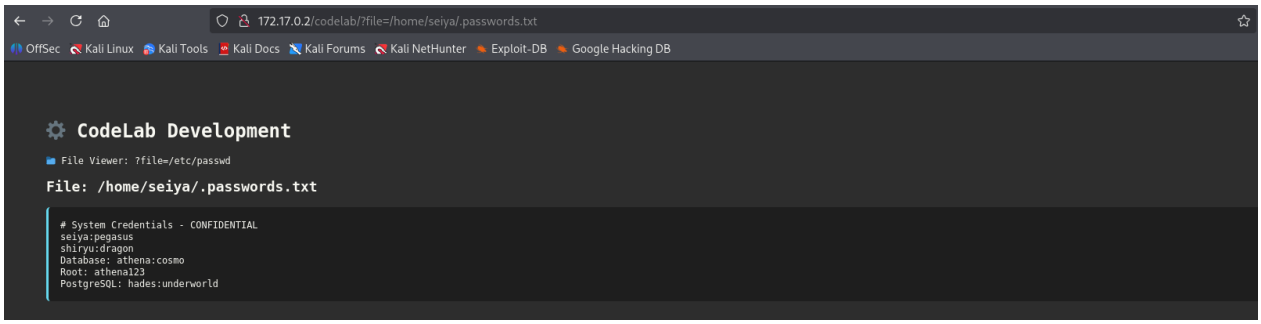
```
kali@kali: ~/maquinas_ctf/vulnerable1
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~/maquinas_ctf/vulnerable1]
└─$ /etc/hosts
zsh: permission denied: /etc/hosts

┌──(kali㉿kali)-[~/maquinas_ctf/vulnerable1]
└─$ ls -la /etc/hosts
-rw-r--r-- 1 root root 124 Sep  9  2025 /etc/hosts
```

- **Config.php**



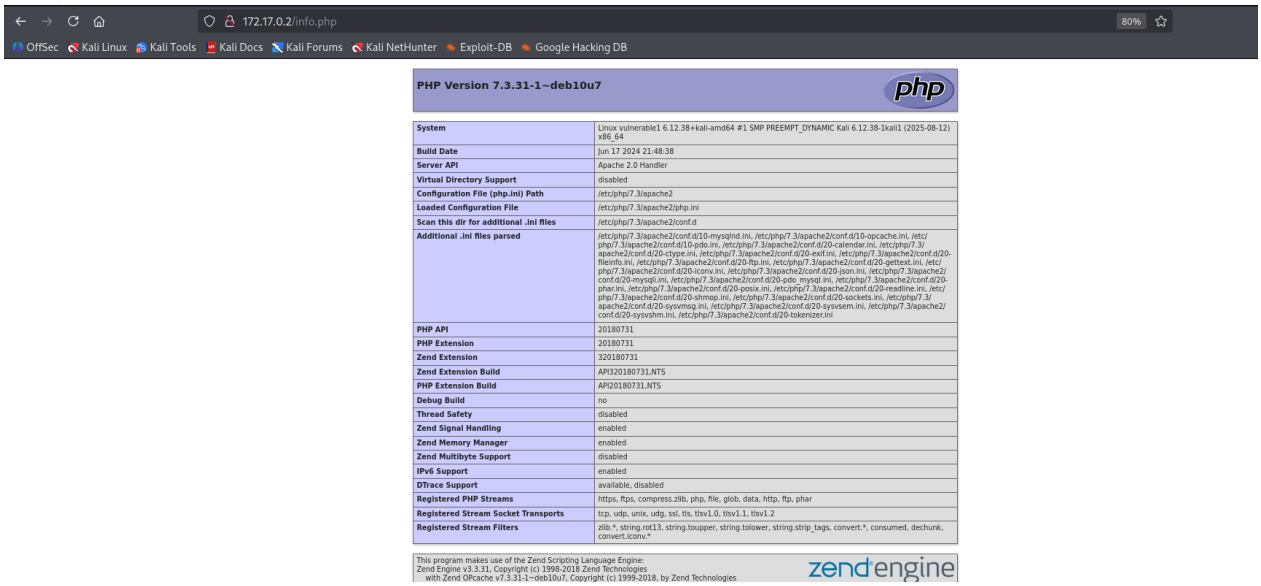
Esta imagen nos dice que el portal **CodeLab** es vulnerable, pero tiene una limitación de visualización para archivos ejecutables del lado del servidor.

- **Passwords.txt**



El archivo contiene una lista de credenciales del sistema etiquetadas como "CONFIDENTIAL".

Al hacer clic en el icono System Information, se despliega toda la configuración del servidor web

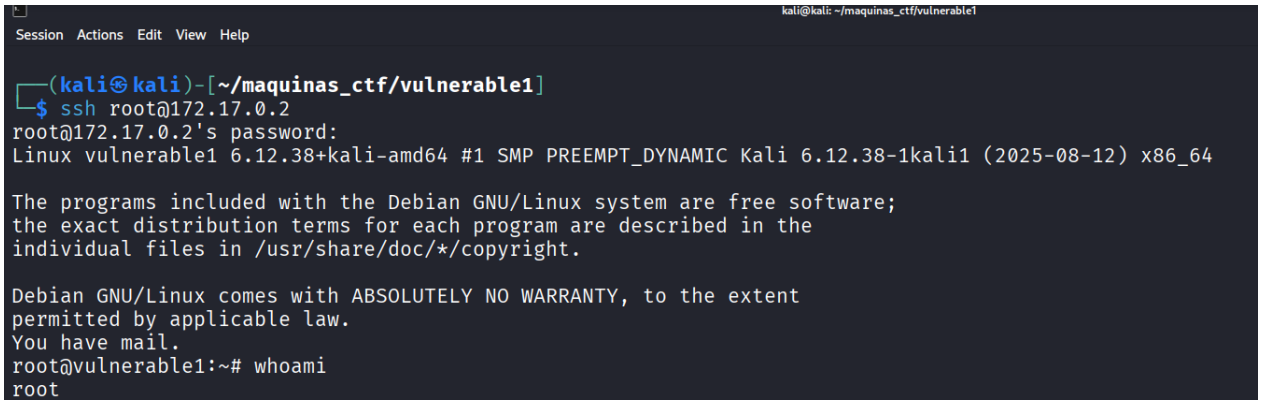


5. Explotación de Vulnerabilidades

5.1. Prueba de Reutilización de Credenciales (SSH)

Luego de realizar la ubicar el archivo con credenciales expuestas se procede a la validación mediante el servicio mediante el comando: **ssh root@172.17.0.2**

- **Usuario probado:** root
- **Contraseña:** athena123
- **Resultado:** Autenticación exitosa.



Una vez que estamos dentro de la maquina con el usuario root,

- procedemos a ingresar al **cd/root** y luego listamos el contenido con el comando: **ls -al**
- Se observa el archivo flag.txt
- Leemos el archivo con el comando: **cat flag.txt** y listo encontramos la bandera de la máquina.

```
kali@kali: ~/maquinas_ctf/vulnerable1
Session  Actions  Edit  View  Help
root@vulnerable1:~#  cd /root
root@vulnerable1:~# ls -al
total 24
drwx------ 1 root root 4096 Apr  7 06:15 .
drwxr-xr-x 1 root root 4096 Apr  5 15:14 ..
-rw------- 1 root root   34 Apr  7 06:15 .bash_history
-rw-r--r-- 1 root root  570 Jan 31  2010 .bashrc
-rw-r--r-- 1 root root  148 Aug 17  2015 .profile
-rw------- 1 root root   53 Jan 24 09:15 flag.txt
root@vulnerable1:~# cat flag.txt
FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}
```

5.2. Validación de la bandera encontrada

```
kali@kali: ~/maquinas_ctf/vulnerable1
Session  Actions  Edit  View  Help

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde vulnerable1.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

  LAB: VULNERABLE 1
  DIFICULTAD: ★☆☆☆☆☆☆☆ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{ ... }): FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}

¡Felicitaciones! Has comprometido Vulnerable 1.

FECHA Y HORA: 2026-04-08 01:57:54 -0400
```

6. Informe Final y Remediación

- **Herramientas utilizadas:** Nmap y Mozilla Firefox
- **Recomendaciones:**
    1. Se recomienda deshabilitar el permiso Anonymous al puerto 21, ya que representa una fuga potencial de información
    2. Deshabilitar el acceso anónimo en FTP.
    3. Configura directivas para limitar el acceso a los archivos que PHP en el servidor.